ZCAS University

MASTER OF SCIENCE IN CYBER SECURITY

CIT5631 - PENETRATION TESTING AND ETHICAL HACKING

FINAL EXAMINATION

8TH JUNE 2026

14:00 – 17:00 HOURS

TIME ALLOWED: READING AND WRITING TIME– THREE HOURS AND FIVE MINUTES

INSTRUCTIONS:

1. Section A: **Question One** in Section A is **compulsory**.
2. Sections B: Answer **TWO** Questions from this section.
3. This examination paper carries a total of **100 marks**.
4. Do Not Open the paper Until told to do so by the Invigilator

SECTION A – COMPULSORY

QUESTION ONE

You are a penetration tester at SecureEdge Ltd. A financial institution, FinVault Bank, has commissioned a black-box penetration test of their internal network. You are provided with only their public IP range: 192.168.10.0/24. Your engagement must follow a formal methodology. The bank uses a mix of legacy Windows servers, Linux web servers, and a wireless network accessible in the lobby. Use the topology reference below throughout this question.

Table 1. FinVault Bank - Simplified Network Topology

Zone	Host / Device	IP Address	OS / Service
DMZ	Web Server	192.168.10.5	Ubuntu 20.04 / Apache 2.4
DMZ	DNS Server	192.168.10.6	Windows Server 2016
Internal LAN	Finance Workstation	192.168.10.20	Windows 10
Internal LAN	DB Server	192.168.10.30	CentOS / MySQL 5.7
Internal LAN	Legacy File Server	192.168.10.50	Windows Server 2008 R2
Wireless (Lobby)	Access Point	192.168.10.100	802.11n — WPA2-Personal
Management	Firewall / Router	192.168.10.1	Cisco IOS

(a) Using the PTES (Penetration Testing Execution Standard) framework, identify and briefly describe the five key phases of the engagement for FinVault Bank. Complete the table below.

Phase #	Phase Name	Key Activities in this Engagement	Tools / Techniques
1			
2			
3			
4			
5			

[10 Marks]

(b) You run the following Nmap command against FinVault's network:

```
nmap -sV -sC -O -p- --open -T4 192.168.10.0/24 -oN finvault_scan.txt
```

Explain what each flag does and why it is appropriate for this engagement. **[6 Marks]**

(c) The scan returns the following output for 192.168.10.50:

```
PORT      STATE  SERVICE        VERSION 445/tcp   open   microsoft-ds   Windows
Server 2008 R2 3389/tcp  open   ms-wbt-server  Microsoft Terminal Services OS:
Windows Server 2008 R2
```

Identify TWO vulnerabilities suggested by this output. For each, state the CVE, the risk level, and your next step. **[6 Marks]**

(d) You decide to exploit the legacy file server using EternalBlue. Write out the complete Metasploit command sequence below, filling in each blank, and explain what the session gives you access to

```
Step 1:  msfconsole
Step 2:  use exploit/windows/smb/_____________________________
Step 3:  set RHOSTS _____________________________
Step 4:  set LHOST  _____________________________
Step 5:  set PAYLOAD windows/x64/meterpreter/_____________
Step 6:  _____________________________
```

[8 Marks]

(e) Once a Meterpreter session opens, list THREE post-exploitation commands you would run and state what each reveal. **[6 Marks]**

(f) A Greenbone scan of the DB server (192.168.10.30) returns three critical findings: CVE-2012-2122 (MySQL authentication bypass), CVE-2016-6662 (RCE via config write), and CVE-2021-27928 (privilege escalation). For each finding, explain in TABULAR form:

(i) how you would manually verify it,

(ii) the business risk if exploited, and

(iii) your recommended remediation. **[14 Marks]**

(50 Marks)

SECTION B - CHOSE ANY TWO

QUESTION TWO

FinVault Bank's lobby provides a WPA2-Personal Wi-Fi network (SSID: FinVault_Guest, channel 6, 2.4 GHz) accessible to customers and staff using a shared passphrase. A social engineering assessment targeting the IT helpdesk team has also been commissioned alongside the wireless test.

(a) Using the Aircrack-ng suite, describe the full step-by-step process to capture a WPA2 4-way handshake from a connected client and perform an offline dictionary attack against the captured file. For each step, write the exact command and explain what it does in tabular form. **[5 Marks]**

(b) Explain TWO conditions that must be met for the dictionary attack to succeed. **[5 Marks]**

(c) You plan an Evil Twin attack to capture staff credentials. Describe the full attack setup:

- the tools used,
- how you configure a rogue access point to impersonate FinVault_Guest,
- the role of DHCP and a captive portal in making the attack convincing
- how victim credentials are harvested. **[5 Marks]**

(d) Recommend TWO technical defences FinVault should deploy to mitigate this attack. **[4 Marks]**

(e) Design a vishing (voice phishing) pretext scenario targeting the FinVault IT helpdesk. Your answer must include: (i) your assumed identity and reason for calling, (ii) the information you are trying to extract, (iii) how you apply at least THREE of Cialdini's principles of influence, and (iv) THREE controls the bank should implement to defend against this attack:

Cialdini Principles Applied

Cialdini Principle	How you apply it in this call
Authority	
Urgency / Scarcity	
Social Proof	

[6 Marks]

QUESTION THREE

Your threat intelligence team suspects that FinVault customer data is being traded on a dark web marketplace. You are legally authorised to conduct passive OSINT on TOR hidden services. The bank is also evaluating AI-driven tools, including AgentZero, to automate parts of future security assessments.

a) Explain how a TOR circuit is established between a client and a .onion hidden service, describing the role and visibility of each of the four nodes: Guard Node, Middle Relay, Exit Node, and Hidden Service. Include TWO known de-anonymisation weaknesses that could expose a user's real identity. **[8 Marks]**

b) You are authorised to conduct passive OSINT to check for FinVault data exposure. Describe THREE specific tools or sources you would use, what each is looking for, and how each remains within legal boundaries. State the key legal principle that separates authorised OSINT from unlawful access. **[9 Marks]**

c) FinVault is evaluating AgentZero as an autonomous AI penetration testing assistant. Explain how it differs from a traditional scanner like Greenbone in terms of reasoning, tool chaining, and adaptability. Using a concrete example, explain what AgentZero can do that Greenbone cannot. Identify TWO ethical risks of deploying it in a live banking environment and propose a safeguard for each. **[8 Marks]**

QUESTION FOUR

Six months after the initial engagement, FinVault Bank has patched all previously identified vulnerabilities and deployed a next-generation SIEM with behavioural analytics, an EDR solution on all endpoints, and a Web Application Firewall in front of its customer portal. You are commissioned to conduct a full adversarial red team exercise. Defenders are now alert. Your objective is to achieve persistent access to the SWIFT payment processing server (192.168.10.99), a system does not present in the original topology, without triggering any SIEM alerts. You have no prior knowledge of the internal network layout beyond the original topology in Question 1.

(a) Name four Windows LOLBins and explain what each enables and why EDR cannot block them. Then describe two advanced in-memory injection techniques that bypass EDR scanning, including what forensic artefact each still leaves. **[12 Marks]**

(b) Describe a full covert lateral movement plan, host enumeration without scan alerts, credential harvesting that avoids SIEM correlation, and use of legitimate protocols to mimic admin traffic. Establish reboot-persistent access without scheduled tasks or run keys. Then analyse a specific SIEM anomaly (3% SMB spike at 02:14), what caused it and how you should have avoided it. **[13 Marks]**

----------END OF EXAMINATION---------